

RAPPORTO DI INCIDENT RESPONSE

Compromissione del dominio CYBERLAB: Lateral Movement via Pass-the-Hash

Severità: **CRITICA (P1)** Stato: CONTENUTO, in remediation

Nota. Documento basato su un'esercitazione in laboratorio controllato (Virtual SOC Home Lab). Nomi host, indirizzi IP, account e artefatti provengono dall'ambiente di test e non da un incidente di produzione. Le marche temporali sono ricostruite dalla telemetria del lab a fini illustrativi.

1. Informazioni sull'incidente

Campo	Dettaglio
ID incidente	INC-2026-0042
Data/ora rilevamento	2026-05-20 14:22:42 (CEST)
Rilevato da	Wazuh, Rule 92650 (Level 12), alert automatico
Analista	Tiziano Becchetti, SOC Analyst Tier 1
Escalation a	SOC Tier 2 / Incident Response Lead
Classificazione	Intrusione: Credential Access + Lateral Movement
Sistemi coinvolti	DC CYBERLAB 192.168.100.20 (WIN-0QND0F71SH9); / Workstation Win10 192.168.100.60 (DESKTOP-S9FVKHS) / origine: Kali 192.168.100.50
Dominio	CYBERLAB (cyberlab.local)
Framework	MITRE ATT&CK, ciclo IR SANS PICERL

2. Sintesi per la direzione (Executive Summary)

Un attaccante presente nella rete interna ha compromesso le credenziali dell'account Domain Administrator tramite avvelenamento LLMNR/NBT-NS, ha ottenuto accesso al Domain Controller, ha disabilitato l'antivirus, ha estratto l'intero database delle credenziali di dominio (incluso l'hash dell'account krbtgt) e si è mosso lateralmente verso una workstation ottenendo privilegi di sistema (NT AUTHORITY\SYSTEM).

Impatto: la compromissione dell'hash krbtgt consente la creazione di Golden Ticket e quindi il controllo persistente dell'intero dominio anche dopo il reset delle altre password. È pertanto richiesto il doppio reset dell'account krbtgt come azione prioritaria. La fase di lateral movement è stata rilevata in meno di 5 secondi dall>alert automatico. La fase di credential dump non ha generato alcun alert e rappresenta un gap di detection documentato in questo rapporto.

3. Valutazione di severità e priorità

Severità assegnata: **CRITICA (P1)**. Motivazione:

- Confidenzialità:** dump completo di NTDS.DIT (tutte le credenziali di dominio, incluso krbtgt).
- Integrità:** controlli di sicurezza manomessi (Windows Defender Real-Time Monitoring disabilitato) e creazione di servizi non autorizzati con privilegi SYSTEM.
- Disponibilità / persistenza:** potenziale Golden Ticket (validità fino a 10 anni), persistenza nel dominio senza il doppio reset di krbtgt.
- Ampiezza:** coinvolti il Domain Controller (asset Tier 0) e almeno una workstation, con le credenziali ottenute l'intero dominio è da considerarsi compromesso.

4. Rilevamento iniziale

Il primo alert ad alta severità è stato Wazuh Rule 92650 (Level 12), "New Windows Service Created to start from windows root path", sulla workstation 192.168.100.60, indicatore tipico di esecuzione remota tramite condivisione ADMIN\$ (Impacket PsExec). Da questo alert ho avviato il triage

ricostruendo a ritroso la kill chain attraverso gli eventi correlati su Wazuh e Security Onion (ricezione via syslog).

Tempo di rilevamento (MTTD) dalla creazione del servizio malevolo all'alert: < 5 secondi.

5. Timeline dell'incidente

Ora (CEST)	Fase	Host	Evidenza	Tecnica
14:02:10	Credential Access: LLMNR/NBT-NS poisoning; cattura NetNTLMv2 di CYBERLAB\Administrator	DC.20 / Kali .50	Responder log, Wazuh rule 100001 (EID 4648)	T1557.001
~ (offline)	Cracking offline dell'hash NetNTLMv2 → password Administrator (usata al passo successivo per il logon WinRM al DC)	Kali .50	hashcat -m 5600	T1110.002
14:11:45	Initial Access: logon remoto via WinRM (evil-winrm) come Administrator	DC .20	EID 4624 logon type 3	T1021.006
14:13:20	Defense Evasion: Set-MpPreference -DisableRealtimeMonitoring \$true	DC .20	Wazuh rule 62152 (canale Defender/Operational)	T1562.001
14:15:02	Credential Access: DCSync/NTDS dump (impacket-secretsdump, DRSUAPI)	DC .20	NON RILEVATO (operazioni legittime di Windows)	T1003.006 / T1003.003
14:22:38	Lateral Movement: Pass-the-Hash con hash NT estratto da NTDS.DIT al passo 14:15 (impacket-psexec) → servizio su ADMIN\$ → shell SYSTEM	WS .60	Wazuh 92650 (L12) + 92652 (L6)×4; SecOnion EID 4624 type 3 NTLM da .50 (12 eventi/39ms; porte 53344/53360/53376/53390)	T1550.002 / T1021.002 / T1543.003
14:22:42	Detection & triage: alert L12 ricevuto dal SOC Tier 1	SOC	Wazuh Rule 92650 Level 12	n/d

Nota: il credential dump via DRSUAPI (riga DCSync) non ha prodotto alert e rappresenta un gap di detection, ripreso nella sezione metriche e nelle lezioni apprese.

6. Ricostruzione dell'attacco (Kill Chain)

Ho rilevato l'incidente nella fase di lateral movement e l'ho ricostruito a ritroso fino all'accesso iniziale. La catena completa:

- **1. Accesso alle credenziali:** Responder ha avvelenato le richieste LLMNR/NBT-NS catturando l'hash NetNTLMv2 di CYBERLAB\Administrator (challenge-response, non utilizzabile in PtH: crackato offline per ottenere la password, usata al passo 2).
- **2. Accesso iniziale:** con la password ricavata, logon al Domain Controller via WinRM (evil-winrm).
- **3. Defense Evasion:** disabilitazione di Windows Defender Real-Time Monitoring.
- **4. Accesso alle credenziali (DCSync):** impacket-secretsdump via DRSUAPI ha estratto NTDS.DIT (Administrator, krbtgt, Sam, Lisa).
- **5. Lateral Movement:** Pass-the-Hash con l'hash NT di Administrator **estratto da NTDS.DIT al passo 4** (non l'hash NetNTLMv2 catturato al passo 1, che è una primitiva crittografica diversa) verso la workstation .60; Impacket ha caricato un binario su ADMIN\$ e creato un servizio temporaneo, ottenendo una shell SYSTEM.

7. Mappatura MITRE ATT&CK

Tattica	Tecnica	ID	Evidenza
Credential Access	Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning	T1557.001	Responder; Wazuh 100001
Credential Access	Brute Force: Password Cracking	T1110.002	hashcat -m 5600 (offline)
Lateral Movement / Initial Access	Remote Services: WinRM	T1021.006	evil-winrm; EID 4624
Defense Evasion	Impair Defenses: Disable AV	T1562.001	Wazuh 62152
Credential Access	OS Credential Dumping: DCSync	T1003.006	secretsdump (DRSUAPI)
Credential Access	OS Credential Dumping: NTDS	T1003.003	dump NTDS.DIT
Lateral Movement	Use Alternate Authentication Material: Pass the Hash	T1550.002	impacket-psexec -hashes
Lateral Movement	Remote Services: SMB/Windows Admin Shares	T1021.002	ADMIN\$; EID 4624 type 3
Persistence / Execution	Create or Modify System Process: Windows Service	T1543.003	Wazuh 92650

Nota: ho classificato il credential dump via DRSUAPI su un Domain Controller come DCSync (T1003.006), più preciso del semplice SAM dumping (T1003.002).

8. Indicatori di compromissione (IoC)

Tipo	Valore
IP origine attacco	192.168.100.50 (Kali)
Host compromessi	192.168.100.20 (DC, WIN-0QND0F71SH9); 192.168.100.60 (DESKTOP-S9FVKHS)
Account compromessi	CYBERLAB\Administrator, krbtgt, Sam, Lisa (intero NTDS)
Hash catturato (NetNTLMv2, da Responder)	Administrator::CYBERLAB:ed141bc713469f31:FA42E817...
Hash NT usato in Pth (da NTDS.DIT via DCSync)	aad3b435b51404eeaad3b435b51404ee:e45a314c664d40a227f9540121d1a29d
Porte sorgente Pth (SMB)	53344, 53360, 53376, 53390
Artefatti su endpoint	Binario temporaneo su ADMIN\$ + servizio Windows temporaneo (PsExec)
Regole di detection	Wazuh 92650 / 92652 / 62152 / 67028 / 61102; SecOnion EID 4624 type 3 NTLM

9. Valutazione dell'impatto

- Dominio CYBERLAB interamente compromesso: tutte le credenziali sono da considerarsi note all'attaccante.
- **Hash krbtgt esfiltrato** → capacità di forgiare Golden Ticket e mantenere accesso privilegiato persistente.
- Domain Controller (Tier 0) e workstation .60 con esecuzione di codice a privilegi SYSTEM.
- Protezione antivirus disabilitata sul DC durante la fase attiva dell'attacco.

10. Contenimento (Containment)

Azioni che ho eseguito nel lab:

- Ho bloccato il traffico verso l'IP attaccante con una regola Windows Firewall (New-NetFirewallRule -DisplayName CONTAINMENT-KALI -Direction Outbound -RemoteAddress 192.168.100.50 -Action Block).

Azioni raccomandate in produzione:

- Isolare immediatamente DC (.20) e workstation (.60) dalla rete (quarantena NAC / disabilitazione porta switch), preservando i sistemi per la forensics.
- Disabilitare gli account compromessi (Administrator e ogni account presente nel dump) e forzare la revoca delle sessioni Kerberos/NTLM attive.
- Bloccare l'IP/host attaccante a livello perimetrale e di segmento.

11. Eradicazione e ripristino

- **PRIORITÀ 1, Doppio reset dell'account krbtgt** (due reset consecutivi con attesa di un intervallo di replica tra i due): obbligatorio perché l'hash krbtgt è stato esfiltrato; senza, qualsiasi Golden Ticket già forgiato resterebbe valido.
- Reset delle password di tutti gli account di dominio presenti nel dump NTDS (a partire da Administrator e dagli account privilegiati).
- Riattivazione e verifica di Windows Defender Real-Time Monitoring sul DC; conferma assenza di esclusioni o manomissioni residue.
- Rimozione del servizio e del binario temporanei lasciati da PsExec su .60; reimaging della workstation (compromissione SYSTEM).
- Verifica di integrità del Domain Controller (o ricostruzione secondo policy IR per asset Tier 0) e ripristino della baseline di sicurezza.

12. Escalation

Ho effettuato escalation immediata da SOC Tier 1 a SOC Tier 2 / IR Lead. Motivazione: la compromissione di un account Domain Admin unita al dump di NTDS.DIT (incluso krbtgt) configura un incidente di livello dominio (P1) che eccede il mio mandato come Tier 1 e richiede l'attivazione del processo di Incident Response formale, il coinvolgimento dell'owner dell'Active Directory e la valutazione di eventuale notifica.

13. Lezioni apprese e raccomandazioni

Gap di detection:

- LLMNR/NBT-NS poisoning non visibile a livello rete nel lab (NAT senza port mirroring): la detection primaria è di rete (Suricata su UDP 5355/137); come compensazione ho adottato una regola endpoint più robusta basata su EID 4624 logon type 3 NTLM con condizioni anti-falsi-positivi.
- Credential dump via DRSUAPI non rilevato: abilitare l'audit dei Directory Service (EID 4662 con i GUID di replica) e il monitoraggio del traffico DRSUAPI su Zeek; aggiungere audit sull'accesso a SAM/NTDS (EID 4656/4663).
- Il canale Microsoft-Windows-Windows Defender/Operational non era attivo di default: senza, la disabilitazione dell'AV sarebbe passata inosservata.

Hardening / mitigazione:

- Disabilitare LLMNR e NBT-NS via GPO (rimuove la causa radice del furto di credenziali).
- WinRM: CbtHardeningLevel = Strict e restringere IPv4Filter agli IP autorizzati; disabilitare Print Spooler sul DC; completare la Security Baseline (score CIS attuale 24%).
- Modello di tiering per gli account amministrativi e adozione di LAPS per gli admin locali, per limitare il riuso di credenziali nel lateral movement.

14. Metriche

Metrica	Valore
MTTD: lateral movement (servizio malevolo)	< 5 secondi
MTTD: disabilitazione antivirus	36 secondi
MTTD: credential dump (DCSync)	Non rilevato (gap, vedi §13)
Eventi correlati su Security Onion (PtH)	12 eventi in 39 ms (4 connessioni SMB)
Stato contenimento	Reversibile / completato nel lab

Appendice: Regole di detection coinvolte

Rule / EID	Descrizione
Wazuh 92650 (L12)	New Windows Service from root path: indicatore primario di PsExec/ADMIN\$
Wazuh 92652 (L6)	Successful Remote Logon, NTLM: possibile pass-the-hash
Wazuh 62152	Windows Defender real-time protection disabled
Wazuh 67028 / 61102	Special privileges assigned / Windows System error (cleanup servizio)
Wazuh 100001 (custom)	LLMNR/NBT-NS poisoning: controllo comportamentale (EID 4648)
SecOnion / EID 4624	Logon type 3, NtLmSsp NTLM V2, sorgente 192.168.100.50